

Overall Security Score

Product: ConsentFlow (consent-manager) · Source-code VAPT · 12 September 2026 · No live exploit testing

8.3 / 10

Overall security score

Strong

Security rating (8.0–8.9)

0

Confirmed Critical in current code

Overall Security Score: 8.3 / 10 — Strong

ConsentFlow is in a production-hardening state. The 11 September Critical/High findings (Owner grant on invite, Next.js RCE advisories, webhook SSRF, Origin-as-auth, stored javascript: XSS) are remediated in code. The score is held below 9.0 by process-local rate limiting, no Postgres RLS, Clerk MFA not verified in-repo, CI gating only critical npm advisories, and leftover console.error logging.

0

Open Critical

1

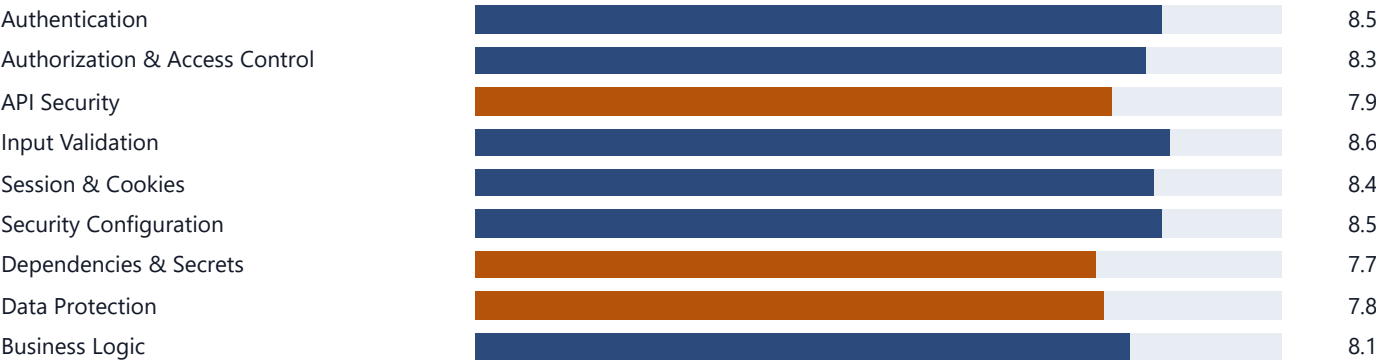
Open High (advisory)

3

Open Medium (confirmed)

Category scores

Each category is scored 0–10. Weighted score = category score × weight. Overall = sum of weighted scores, rounded to one decimal place.



Source: VAPT category model applied to current repository evidence · 12 Sep 2026. Markers: 8.0 Strong, 9.0 Excellent.

Category	Score / 10	Weight	Weighted score
Authentication	8.5	15%	1.28
Authorization & Access Control	8.3	20%	1.66
API Security	7.9	15%	1.19
Input Validation	8.6	15%	1.29
Session & Cookies	8.4	10%	0.84
Overall	8.3 / 10	100%	8.30

Category	Score / 10	Weight	Weighted score
Security Configuration	8.5	10%	0.85
Dependencies & Secrets	7.7	5%	0.39
Data Protection	7.8	5%	0.39
Business Logic	8.1	5%	0.41
Overall	8.3 / 10	100%	8.30

Score explanation

1. Why this score

8.3 reflects a codebase that already has Clerk session auth, edge auth.protect(), org-scoped queries, operator RBAC on keys/webhooks/publish, CSRF fail-closed, SDK origin allowlisting, HMAC production secrets, and patched Next.js 16.3.4. It is not 9.0 because public APIs still use an in-process rate-limit map, tenant isolation is application-only (no RLS), and MFA / remaining npm highs are not verified in this repository.

2. Strongest controls

Clerk + webhook role mapping (invitees are no longer auto-Owner). Only Owner can assign Owner. Webhook delivery reuses the scanner SSRF guard with redirect: manual. Portable consent requires a Clerk session, not a spoofable Origin. Banner/SDK URLs and colors are sanitized. CSRF rejects cookie mutations with no Origin/Referer. Production boot fails without dedicated HMAC/webhook secrets.

3. Biggest weaknesses

Process-local rate limiting will not hold across serverless isolates. No Postgres row-level security. CI npm audit only fails on critical. Many routes still use console.error instead of the redacting logger. Clerk MFA is a dashboard setting, not evidenced here. Members can still CRUD websites, drafts, and vendors (operator-gated paths are the privileged ones).

4. Findings with the greatest score impact

SEC-011 (in-memory rate limit) is the main drag on API Security (7.9, 15% weight). SEC-024 (no RLS) and remaining Member write scope drag Authorization (20% weight). SEC-026-class transitive highs and critical-only CI drag Dependencies. SEC-022 console.error drags Data Protection. No confirmed Critical remains, so the 4.0 cap rule does not apply.

5. To reach 8/10

Already met. Keep production secrets and the Clerk membership webhook configured; do not regress Owner-grant, SSRF, CSRF, or origin allowlist controls.

6. To reach 9/10

Ship distributed rate limiting (Redis/Upstash/KV) and stop trusting spoofable X-Forwarded-For. Add Postgres RLS (or equivalent) for organization_id. Verify Clerk MFA on the production tenant. Raise CI to npm audit --audit-level=high and clear remaining highs. Replace console.error with the structured logger.

7. To reach 10/10

Also: transactional last-Owner protection, sanitize vendor URLs on write (not only SDK render), split public health vs authenticated readiness, least-privilege Member (read/draft only), secret scanning in CI, SIEM/alerting on Owner changes and key/webhook create, and a two-tenant live retest that verifies the remediations — not just that recommendations exist.

Target score after remediation

These are estimated scores, not guaranteed. The score should rise only after the weakness is actually fixed and, ideally, retested.

8.3 / 10

Current score

8.5 / 10

Estimated after remaining High

8.9 / 10

Estimated after all recommended

How the estimates were formed

After remaining High: patch transitive image-codec advisories and any leftover privileged Member paths — about +0.2. After all recommended: distributed rate limit, RLS, verified MFA, logger cleanup, and high-level CI audit — about +0.6, still short of 9.0 until those controls are retested. Do not treat this as a 10/10 projection.

Residual findings used in scoring

ID	Severity	Category impact	Status
SEC-011	Medium	API Security	Confirmed — in-memory rate limit
SEC-024	Medium	Authorization	Confirmed — no Postgres RLS
SEC-022	Medium	Data Protection	Confirmed — console.error still widespread
SEC-026	High (advisory)	Dependencies	Not re-audited this pass; CI gates critical only
MFA	Informational	Authentication / Session	Not verified — Clerk Dashboard setting

Category scoring notes

- Authentication 8.5.** auth.protect(), Clerk webhooks, hashed API keys, cron timing-safe compare. Minus unverified MFA.
- Authorization 8.3.** Clerk role map, Owner-only Owner assign, requireOperatorRole on keys/webhooks/publish/scanner. Minus no RLS and Member CRUD on sites/policies/vendors.
- API Security 7.9.** CSRF fail-closed, origin allowlist, portable consent session-auth, siteKey on consent GET/withdraw. Minus process-local rate limits on public DSAR/consent.
- Input Validation 8.6.** Drizzle parameterization, sanitizeHttpRequest / safeHttpRequest, CSS color allowlist, inArray. Minus vendor POST storing unsanitized URLs (SDK still sanitizes on render).

Session & Cookies 8.4. Clerk-managed sessions, CSRF origin check, COOP same-origin. Cookie flags and lifetime not independently verified beyond Clerk defaults.

Security Configuration 8.5. CSP strict, HSTS in production, COOP, frame-src https-only, GitHub Actions CI. Health remains unauthenticated.

Dependencies & Secrets 7.7. next@16.3.4, production secret throws, webhook secrets encrypted at rest. CI audit-level=critical only.

Data Protection 7.8. Org-scoped queries, hashed keys, logger redaction. Public SDK still returns notice contacts when origin is allowed; DSAR tokens still returned in intake JSON.

Business Logic 8.1. Consent stateVersion lock, policy HMAC, compliance validator ignores client claims. Residual last-Owner TOCTOU and Member draft/config writes.

ConsentFlow VAPT Overall Security Score · Evidence-based source-code assessment · Scores improve only after verified remediation, not because recommendations were written.